Automated VAPT Assessment & Triage Report

1. Engagement Scope & Rules of Engagement

Authorized Target Scope: 127.0.0.1:3000

Execution Timestamp: 2026-11-08 17:42:49

Rules of Engagement: Non-destructive local sandbox testing restricted strictly to authorized loopback assets.

2. Tools & Ingestion Sources

- Nmap Network Mapper: Live Subprocess Discovery
- OWASP ZAP (Web Application Scan): Import (Sample Data)
- Nikto (Server Configuration): Import (Sample Data)
- Nessus, OpenVAS/Greenbone, Burp Suite: Planned (not integrated) | Metasploit: Unsupported (lab-only, human-run)
- Correlation & Prioritization Engine: Google Gemini (gemini-3.8-flash)

3. Risk Posture & Severity Distribution

Overall Posture Rating: MEDIUM

Severity Counts: Critical: 0 | High: 1 | Medium: 0 | Low: 4

4. Executive Summary

Security assessment of target 127.0.0.1 revealed an open service on port 3000 exposing an Express web application impacted by a high-severity SQL injection vulnerability. Supporting findings include missing defensive headers such as Content Security Policy and X-Frame-Options, as well as technology disclosure via the X-Powered-By header.

5. Attack Path Synthesis

An attacker probes port 3000 and determines that an Express web application is active via the X-Powered-By header. The attacker then targets application input fields using the SQL injection payload '' OR 1=1--' (ZAP-40018), enabling unauthorized database query manipulation. In parallel, the absence of Content Security Policy and X-Frame-Options headers leaves clients exposed to potential framing and script injection risks.

6. Remediation Roadmap

Priority 2 | ID: NIKTO-999101 | Owner: DevOps / Backend

Action: Configure the X-Frame-Options HTTP response header (e.g., DENY or SAMEORIGIN) to prevent clickjacking.

Priority 3 | ID: ZAP-10038 | Owner: DevOps / Backend

Action: Define and enforce a strict Content Security Policy (CSP) header in HTTP responses.

Priority 5 | ID: NMAP-3000 | Owner: SecOps

Action: Review port 3000 exposure and apply firewall rules if public network access is not required.

7. Finding Evidence & Provenance (5)

[LOW] Open Network Port: 3000 (service unidentified; Nmap port-table guess: ppp) (Tool: Nmap)

Target: 127.0.0.1:3000 | Confidence: 90% | Status: Reachable (HTTP 200); vulnerability not confirmed
Raw Source: outputs\nmap_target.xml
Trust Justification: Direct network enumeration: TCP connection and service response received.
Evidence: Port 3000/tcp open. Service (Nmap): service unidentified; Nmap port-table guess: ppp

[HIGH] SQL Injection (Tool: OWASP ZAP)

Target: 127.0.0.1:3000 | Confidence: 95% | Status: Rejected by Analyst
Raw Source: imports\sample_zap_report.json
Trust Justification: Verified: Nmap independently confirmed port 3000 is open and reachable.
Evidence: ' OR 1=1--

[LOW] Content Security Policy (CSP) Header Not Set (Tool: OWASP ZAP)

Target: 127.0.0.1:3000 | Confidence: 100% | Status: Reachable (HTTP 200); vulnerability not confirmed
Raw Source: imports\sample_zap_report.json
Trust Justification: Verified: Nmap independently confirmed port 3000 is open and reachable.
Evidence: Content Security Policy is missing from response headers.

[LOW] Sample Data: Server leaks information via X-Powered-By header: Express (Tool: Nikto (Import))

Target: 127.0.0.1:3000 | Confidence: 85% | Status: Rejected by Analyst
Raw Source: imports\sample_nikto_report.json

Trust Justification: Verified: Nmap independently confirmed port 3000 is open and reachable.
Evidence: Sample Data: Server leaks information via X-Powered-By header: Express

[LOW] Sample Data: Anti-clickjacking X-Frame-Options header is not present. (Tool: Nikto (Import))

Target: 127.0.0.1:3000 | Confidence: 85% | Status: Reachable (HTTP 200); vulnerability not confirmed
Raw Source: imports\sample_nikto_report.json
Trust Justification: Verified: Nmap independently confirmed port 3000 is open and reachable.
Evidence: Sample Data: Anti-clickjacking X-Frame-Options header is not present.

8. Limitations & Audit Trail

Limitations: Testing was strictly non-destructive and scoped solely to approved target ports. Safe HTTP probes evaluate endpoint reachability without verifying payload execution.

[2026-11-08 17:41:49] [AUTHORIZED] Plan approved by analyst for 127.0.0.1:3000
[2026-11-08 17:42:02] [OK] Nmap scan completed: 1 port(s) detected
[2026-11-08 17:42:17] [OK] Correlation completed via Google Gemini (gemini-3.8-flash)
[2026-11-08 17:42:38] [VERIFIED] Benign probe on NMAP-3000 -> Reachable (HTTP 200); vulnerability not confirmed
[2026-11-08 17:42:43] [VERIFIED] Benign probe on ZAP-10038 -> Reachable (HTTP 200); vulnerability not confirmed
[2026-11-08 17:42:44] [REJECTED] Finding ZAP-40018 rejected by analyst
[2026-11-08 17:42:47] [REJECTED] Finding NIKTO-999100 rejected by analyst
[2026-11-08 17:42:49] [VERIFIED] Benign probe on NIKTO-999101 -> Reachable (HTTP 200); vulnerability not confirmed